



## Lab 7 — Design the Governance Operating Model and RACI

### Topic 02: Building an AI Governance Framework: Policies, Roles and Risk Ownership

**Objective:** Evaluate accountability requirements and develop a governance operating model with committee structure, roles and a control-level RACI.

**Goal:** Policies fail without owners. You will design NovaBank's AI governance operating model: the committee that decides, the roles that execute, and a RACI matrix that removes ambiguity from the twelve controls you have identified so far.

**What you'll build:** A governance operating model diagram, committee terms of reference, six role descriptions and a RACI matrix covering twelve AI governance controls.

**Tools and data:** Org chart (novabank-org-chart.md), role catalogue, RACI template

#### Data files in this lab

- data/committee-tor-template.md
- data/novabank-org-chart.md
- data/raci-template.csv

#### Step-by-step

1. Open novabank-org-chart.md in labs/lab-07-operating-model/data/ and identify which existing forums and roles you can reuse. Building a parallel governance structure is a known failure mode — reuse first.
2. Define the AI Governance Committee: purpose, membership, chair, quorum, meeting frequency and — critically — its decision rights. A committee that can only advise cannot govern.
3. Write the escalation path: which decisions the committee takes, which go to the executive risk committee, and which reach the board. Name the trigger for each escalation.
4. Define six roles with one paragraph each: Executive Accountable Owner, AI Governance Lead, AI System Owner, Data Protection Officer, Security Lead and Model/Agent Developer.
5. For each role state the one decision that role owns outright. If two roles claim the same decision, resolve it now — that conflict will otherwise surface during an incident.
6. Build the RACI across twelve controls: inventory maintenance, risk assessment, data approval, model approval, pre-deployment testing, deployment sign-off, human-

oversight design, monitoring, logging, incident response, third-party AI review and decommissioning.

7. Apply the single-A rule: exactly one Accountable per control. Multiple A's mean nobody is accountable — fix every row that breaks this rule.
8. Cross-check the RACI against NIST GOVERN 2.1 roles and responsibilities and GOVERN 2.3 executive accountability, and record how your model satisfies each.
9. Stress-test the model: walk through the Lab 3 NovaAssist prompt-injection incident and confirm your model shows who detects it, who decides to disable the agent, and who notifies the PDPC if personal data was exposed.

### **Test it**

Every one of the twelve controls has exactly one Accountable role. Walking the NovaAssist incident through your model produces a named person at every step, with no gaps and no two people claiming the same decision.

*Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.*